EWB CYBERSECURITY

# Assessment 01

# Security Foundations

## AI-Powered Cybersecurity

| | |
|---|---|
| **Student name** | Yawar Hassan |
| **Batch / Group** | Not provided |
| **Assessment** | Assessment 01: Security foundations |
| **Issued** | 18 October 2026 |

*Prepared using the fictional scenarios and instructions in the supplied assessment. The analysis separates observed evidence from interpretation and avoids claiming certainty where the evidence is incomplete.*

AI-use declaration: AI assistance was used to help draft and organise the explanations in this report. The final report should be reviewed and understood by the student before submission.

# Task A — Secure a student account (25 marks)

## A1–A2. Risks, assets, CIA impact, controls and limitations

Mira's scenario includes password reuse, unexpected sign-in prompts, postponed updates, a single project copy, and a friend using a signed-in account. The table connects each issue to an asset and a practical control.

| Risk | Asset at risk | CIA impact | Practical control | Limitation |
|---|---|---|---|---|
| Same short password used for email and portal | Email, learning portal, coursework and account data | Confidentiality: one exposed password could expose both accounts. Integrity: someone could alter work or settings. | Use a unique, long password for each account; store it in a reputable password manager if permitted. | A password manager still needs a strong master password and device protection. |
| Approves unexpected sign-in prompts | Account access and personal/course information | Confidentiality and integrity: an unauthorised sign-in may be approved. | Deny unexpected prompts; report repeated prompts; use number matching or phishing-resistant MFA if offered. | MFA can still be defeated by a user approving a malicious prompt or by other account-recovery weaknesses. |
| Postpones device updates | Laptop, saved files and accounts used on the device | Confidentiality, integrity and availability may be affected if known weaknesses remain unpatched. | Enable automatic updates and restart promptly when updates require it. | Updates do not prevent every attack and should come from the device's official update mechanism. |
| Only project copy is on one laptop | Project files and coursework | Availability: device loss, failure or ransomware could make the only copy unavailable; integrity may also be affected. | Keep a separate backup, such as an approved cloud backup or external drive, and test that files can be restored. | A connected or synchronised backup may also be affected; keep version history or a separate copy. |
| Friend uses laptop while Mira remains signed in | Portal session, email, private files and account settings | Confidentiality: the friend may see private information. Integrity: accidental or intentional changes may be made. | Sign out or lock the device before sharing; use separate OS accounts with standard permissions. | A lock helps only when used consistently; separate accounts do not protect files that are deliberately shared. |

## Priority order — first three actions

**1. Stop approving unexpected sign-in prompts and secure the accounts.** This is first because an attacker may be trying to gain access right now. Mira should deny the prompt, change reused passwords from a trusted device, and review active sessions. If she suspects compromise, she should contact the college's official IT support.

**2. Create a separate backup of the project.** Coursework may be impossible to recreate if the laptop is lost, damaged or compromised. A verified backup improves availability.

**3. Update the device and change account-sharing habits.** Updates reduce exposure to known vulnerabilities; locking the device and using separate accounts reduces accidental or unauthorised access. These are important, but the unexpected sign-in prompts deserve immediate attention.

## A3. Authentication versus authorisation

**Authentication** checks who Mira is—for example, signing in to the learning portal with her username, password and an MFA approval. **Authorisation** determines what an authenticated user is allowed to do—for example, Mira may be allowed to view and submit her own assignments, while only a lecturer may edit grades. Successful authentication does not automatically grant permission to every portal function.

# Task B — Analyse a suspicious message (25 marks)

## B1. Warning-sign table

The message is suspicious based on its wording and the evidence provided, but the text alone does not prove who sent it or establish that a real website is malicious.

| Relevant phrase | Why it needs scrutiny |
|---|---|
| “FINAL WARNING” and “expires in 20 minutes” | Urgency and threat of losing a benefit pressure the recipient to act before checking the claim. |
| From: “awards@campus-awards.example” but Reply-To: “help@personal-awards.example” | The sender and reply addresses differ. That mismatch is a reason to verify the sender through an independent official channel; it is not by itself proof of fraud. |
| “enter your college password and OTP” | A request to provide both a password and a one-time passcode is dangerous. The student should never send these secrets in response to an email or unverified page. |
| “Do not contact the college office” | The message discourages independent verification, which is a strong social-engineering warning sign. |
| “Reply with a photo of your identity card” | It asks for sensitive identity information through an unverified channel, creating privacy and identity-misuse risks. |

## B2. Safe verification process

1. Do not click the message link, reply, enter credentials or send an identity-card photo. Preserve the message for review.

2. Open the college portal using a bookmark or an address already known from official college materials, or contact the scholarship/college office using a phone number or email address obtained independently. Do not use contact details supplied only in the suspicious message.

3. Ask whether the scholarship, deadline and message are genuine. If the office confirms that the message is suspicious, report it using the college’s approved reporting process.

HTTPS only indicates that the browser connection to a site is encrypted and that a certificate was presented for that domain; it does not prove that the site or the person operating it is trustworthy. A familiar display name can be chosen or imitated, so the actual address and independent verification matter.

## B3. Response plan if a password and OTP were already entered

1. **Contain access:** from a trusted device, go directly to the genuine college portal or email provider. Change the exposed password immediately, and change it anywhere else it was reused. Do not share the password or OTP with anyone.

2. **Revoke access:** sign out other sessions if the service supports it; check recovery email/phone details, MFA methods, forwarding rules and recent account activity. Remove changes that the student did not make, following official support guidance.

3. **Report promptly:** contact college IT/security through independently obtained official details and report the suspicious message. If identity-card information was also sent, tell the college’s appropriate privacy/security contact and follow their guidance.

4. **Follow up:** watch for unfamiliar sign-ins, messages sent from the account, changes to files or settings, and unexpected MFA prompts. Keep the message and relevant timestamps as evidence. If the same password was used elsewhere, secure those accounts too.

## B4. What cannot be established from this message alone

The message alone cannot establish the true sender, whether the linked domain is controlled by an attacker, or whether a real scholarship has been approved. Helpful additional evidence would include full email headers, independently verified information from the college, and review by authorised IT staff of the domain and relevant security logs. The sample addresses are fictional training examples and should not be visited.

# Task C — Triage a sign-in alert (25 marks)

## C1. Four-point timeline: observed evidence and interpretation

| Time (IST) | Observed evidence | Interpretation / uncertainty |
|---|---|---|
| 09:00–09:01 | student07 has a successful password event from 192.0.2.10, followed by an approved MFA event. Lab notes identify this IP as the usual classroom egress. | This is consistent with a normal sign-in, but the log alone does not prove who used the account. |
| 10:14–10:16 | Two password attempts from 198.51.100.23 fail; a password attempt from the same IP then succeeds. | The sequence could indicate repeated guessing or use of a previously obtained password. The IP is a source address in the log, not an identity. |
| 10:17–10:18 | MFA is denied and then approved from 198.51.100.23. The user says they did not sign in after 09:05 and approved a prompt at about 10:18 because they thought it would stop repeated requests. | The user's statement and the approved MFA event suggest the approval may have enabled access the user did not intend. It remains possible that log details or the statement need further verification. |
| 10:20 | A session is created after the password success and MFA events. | This is consistent with a successful session being established. The authorised IT team should confirm session details and determine what activity followed. |

## C2. Likely explanation, alternative and distinguishing checks

**Likely explanation:** someone other than the student may have obtained or guessed the password, triggered repeated MFA requests, and gained access after the student approved a prompt. The successful password event, MFA denial followed by approval, and later session creation support this as a concern. The log does not identify a person or prove exactly how the password was obtained.

**Alternative explanation:** the student may have initiated or indirectly caused the sign-in from a different network or device and misunderstood the timing, or the records may reflect an unusual but legitimate access path. This is less consistent with the user's statement, but should still be checked rather than ruled out without evidence.

**Two useful checks:** (1) review authorised identity-provider and endpoint records for device/browser details, session identifiers, MFA method and activity after 10:20; compare them with the student's known devices and activity. (2) Interview the student using safe, non-leading questions and check whether they recognise the device/session or any actions after 10:20. Do not ask for passwords or OTPs. The reserved documentation IP addresses do not identify a real person.

## C3. Three prioritised actions for the authorised IT team

**1. Protect the account:** revoke the suspicious session and other active sessions as appropriate, reset the password through the official process, review MFA methods and recovery details, and ensure the student denies unexpected prompts going forward.

**2. Preserve evidence:** export the relevant authentication, MFA and session logs with timestamps and time zone; record the actions taken and preserve related endpoint/security telemetry under the organisation’s procedure. Avoid deleting or altering the original logs.

**3. Investigate scope and impact:** review activity after session creation, including file access, account-setting changes, messages and new authentication methods. Check for other affected accounts or repeated patterns, then document findings and notify the appropriate security contact.

## C4. Incident summary (60–100 words)

On 18 October 2026, student07 had a successful sign-in from the usual classroom egress at 09:00–09:01. At 10:14–10:16, two password attempts from a different documentation IP failed before a password attempt succeeded. MFA was denied at 10:17 and approved at 10:18, followed by session creation at 10:20. The student reports not signing in after 09:05 and says the prompt was approved unintentionally. Unauthorised access is a plausible explanation, but the logs do not identify a person or prove the password’s source. Revoke sessions, secure the account and preserve logs for review.

# Task D — Review an AI security answer (25 marks)

## D1. Five unsafe or unsupported claims/actions and corrections

| AI output claim/action | Correction and reasoning |
|---|---|
| “The email is safe because it uses HTTPS.” | Incorrect. HTTPS encrypts the connection but does not prove that the site or message is legitimate. The urgency, mismatched Reply-To, request for a password/OTP and identity-card photo require independent verification. |
| “The sign-in logs prove that the person using 198.51.100.23 stole the password.” | Unsupported. The logs show failed and successful password events from a source IP, followed by MFA events and session creation. They do not identify a person or establish how the password was obtained. An IP address alone is not proof of identity. |
| “MFA prevents every account compromise.” | Incorrect. MFA adds a layer of protection, but an unexpected prompt can be approved by mistake, as the scenario suggests. Users should deny unrecognised prompts and report repeated requests; stronger MFA options may reduce some risks but are not a guarantee. |
| “Delete the suspicious logs.” | Unsafe. Logs are evidence needed to understand the event and its scope. The authorised IT team should preserve relevant records and follow the organisation’s evidence-handling process rather than delete them. |
| “Send the student’s password to support so they can test it.” | Unsafe. Passwords and OTPs are secrets and should not be shared. Support should use approved account-recovery and verification procedures without asking the student to disclose credentials. |

## D2. Improved prompt for an AI tool

*“Analyse only the fictional evidence supplied in this assessment. For each conclusion, separate directly observed facts from interpretations and assumptions. Identify warning signs and reasonable alternative explanations. Do not claim that an IP address identifies a person, that HTTPS proves a message is safe, or that MFA guarantees security. Do not request or reproduce passwords, OTPs, identity documents or real personal data. Recommend safe, proportionate response actions, including account protection and preservation of relevant evidence. State what cannot be established from the supplied evidence and identify what additional evidence an authorised security team could check. Keep the answer beginner-friendly and refer to trustworthy security guidance where relevant.”*

## D3. Corrected security advice (100–150 words)

Treat the scholarship message as suspicious because it creates urgency, discourages independent contact, uses a different Reply-To address, and asks for a password, OTP and identity-card photo. Do not click its link or reply with sensitive information. Verify the scholarship through the college portal or an official contact found independently. HTTPS and a familiar display name do not prove that a message is genuine. The sign-in logs show password failures followed by a success, an MFA denial and approval, and session creation; together with the student's statement, this raises concern about possible unauthorised access. However, the logs do not identify a person or prove how the password was obtained. The authorised IT team should secure the account, revoke suspicious sessions, preserve logs, and review activity after the session was created. Never send passwords or OTPs to support.

## D4. AI-use declaration and evidence/reference notes

**AI-use declaration:** AI assistance was used to organise and draft the explanations, tables and incident summary in this report. The supplied assessment scenarios were treated as fictional. The report should be reviewed for understanding and accuracy before submission.

**Evidence note 1 — supplied assessment:** The report uses the fictional account scenario, suspicious-message text, synthetic sign-in log and AI-output excerpt in EWB Assessment 01, pages 1–4. Conclusions about student07 are based on the events and statement printed in Task C; they are not claims about a real account.

**Evidence note 2 — CISA:** CISA’s Secure Our World guidance is listed by the assessment as a reference for basic account security and phishing guidance: https://www.cisa.gov/secure-our-world

**Evidence note 3 — NIST:** The assessment lists the NIST Generative AI Profile (AI 600-1) as a reference for issues such as AI confabulation and the need to verify output: https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

# References and submission checklist

## References

[1] EWB Courses. *Assessment 01: Security foundations*. AI-Powered Cybersecurity, issued 18 October 2026. Supplied assessment PDF, pages 1–4.

[2] Cybersecurity and Infrastructure Security Agency (CISA). *Secure Our World*. https://www.cisa.gov/secure-our-world

[3] National Institute of Standards and Technology (NIST). *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile*, AI 600-1. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

## Before submitting

• Confirm your batch/group details and update the cover page if needed.

• Read each answer and make sure you can explain the reasoning in your own words.

• Check that the report follows any later instructions or formatting requirements shared by EWB.

• Save the final PDF using the requested naming pattern: EWB_Cyber_Assessment01_YourName.pdf.

• Keep the report until the official Google Form is shared; the assessment says the submission deadline will be announced separately.

*Important note: This report is a draft prepared from the supplied assessment. It does not establish that any real email, domain, account or IP address is malicious. All scenario-specific data in the assessment is fictional.*